Étude de Cas EBIOS Risk Manager : Sécurisation d'une Base Militaire de Command and Control (C2)

Introduction :

Cette étude de cas analyse la sécurisation d'une base militaire Command and Control (C2), responsable du commandement opérationnel, de la coordination des unités sur le terrain, de l'échange d'informations de renseignement et de la gestion des communications tactiques. L'infrastructure examinée inclut un serveur de commandement, un réseau interne militaire, des liaisons de communication et télécommunications satellitaires, ainsi qu'un stockage sécurisé de données classifiées contenant des plans d'opération hautement confidentiels.

Dans ce contexte stratégique, les menaces majeures sont identifiées comme provenant d'acteurs étatiques, d'opérations de cyberespionnage et de risques internes. Cette analyse, basée sur la méthode EBIOS Risk Manager (EBIOS RM) de l'ANSSI, vise à déterminer les risques affectant les missions critiques de la base C2, puis à définir une stratégie de traitement adaptée au niveau de menace constaté.

Atelier 1 : Cadrage et Socle de Sécurité

Objectif

Ce premier atelier définit le périmètre de l'étude, identifie les missions essentielles de la base C2, les actifs critiques à protéger, les valeurs métier prioritaires, les événements redoutés et le socle de sécurité existant.

Périmètre de l'étude

Élément	Contenu
Objet de l'étude	Sécurisation d'une base militaire de Command and Control (C2)
Mission principale	Commander les opérations, coordonner les unités, échanger du renseignement militaire et maintenir les communications tactiques
Périmètre métier	Conduite des opérations militaires, diffusion d'ordres, protection du renseignement, disponibilité des communications C2, conservation des plans top secret

Élément	Contenu
Périmètre technique	Command server, réseau interne militaire, liaisons de communication, télécommunications satellitaires, stockage sécurisé de données classifiées
Parties prenantes	État-major, officiers opérationnels, analystes renseignement, équipes SI, prestataires de communication satellite

Valeurs métier et événements redoutés

Les valeurs métier sont les éléments essentiels au bon accomplissement de la mission de la base C2. Les événements redoutés correspondent à ce qui pourrait compromettre ces valeurs métier.

Valeur métier	Événement redouté
Ordres opérationnels	Altération ou interception d'ordres transmis aux unités
Données de renseignement	Exfiltration ou divulgation d'informations sensibles
Communications tactiques	Coupure ou perturbation des communications C2
Plans classifiés	Accès non autorisé ou fuite de plans d'opération top secret
Disponibilité du commandement	Indisponibilité du command server ou sabotage technique

Socle de sécurité

Le socle de sécurité regroupe les mesures de base obligatoires et reconnues comme mises en place. Pour une base C2, il comprend :

- Segmentation réseau de base entre zones opérationnelles et administratives
- Chiffrement des communications sensibles
- Contrôles d'accès physiques aux installations critiques
- Politique de gestion des habilitations militaires
- Journalisation des événements de sécurité
- Procédures de sauvegarde des données classifiées

Atelier 2 : Sources de Risque et Objectifs Visés

Objectif

Lors de l'atelier 2, on détermine les sources de risque (SR) ainsi que leurs objectifs visés (OV), en cherchant à répondre à la question suivante : qui ou quoi pourrait menacer les missions et les valeurs métiers définies lors de l'atelier 1, et dans quel but ?

Sources de risque et objectifs visés

Les principales sources de risque pour une base C2 sont généralement les acteurs étatiques, les groupes spécialisés dans le cyber espionnage, les menaces internes malveillantes et, dans une moindre mesure, les prestataires ou agents négligents.

Source de risque	Objectif visé	Motivation	Niveau de gravité
Acteur étatique	Obtenir des données sensibles, perturber les capacités opérationnelles	Renseignement stratégique, déstabilisation, influence	Très élevé
Groupe de cyber espionnage	Exfiltrer des informations classifiées	Espionnage politique, militaire ou économique	Très élevé
Menace interne malveillante	Divulguer, voler ou altérer des données	Vengeance, profit, idéologie	Élevé
Personnel négligent	Faciliter une compromission involontaire	Erreur humaine, mauvaise pratique	Moyen à élevé

Vulnérabilités associées

Les faiblesses techniques et organisationnelles qui rendent possibles l'atteinte de ces objectifs comprennent :

- Systèmes non corrigés ou obsolètes
- Contrôles d'accès insuffisants ou trop permissifs
- Segmentation réseau faible
- Absence de surveillance avancée et de détection d'anomalies
- Exposition à l'ingénierie sociale et au phishing
- Gestion insuffisante des accès privilégiés

Atelier 3 : Scénarios Stratégiques

Objectif

L'atelier 3 a pour objectif d'élaborer des **scénarios stratégiques**, définissant les **chemins d'attaque de haut niveau** susceptibles d'être empruntés par une source de risque afin d'atteindre son objectif. Ces scénarios sont conçus à l'échelle de l'**écosystème** ainsi qu'en fonction des **valeurs métier** propres à la base C2.

Scénarios stratégiques

Scénario stratégique	Chemin d'attaque probable	Impact principal
Cyber espionnage d'État ciblant des plans classifiés	Hameçonnage d'un officier → compromission de sa messagerie → rebond sur le réseau interne → élévation de privilèges → accès au stockage sécurisé → exfiltration discrète	Atteinte à la confidentialité, perte de renseignement stratégique, impact sur la souveraineté
Initié divulguant des informations sensibles	Abus de droits légitimes → copie de données classifiées → transmission externe via canal non surveillé	Fuite d'informations critiques, perte de confiance institutionnelle
Compromission du command server	Exploitation d'une vulnérabilité non corrigée → prise de contrôle → altération d'ordres ou sabotage de fonctions critiques	Perte d'intégrité des ordres, interruption de mission, confusion opérationnelle
Attaque via la chaîne d'approvisionnement ou prestataire satellite	Rebond par un prestataire de communication compromis → accès indirect au réseau C2 → interception ou perturbation des flux	Compromission indirecte, perte de disponibilité des communications

Atelier 4 : Scénarios Opérationnels

Objectif

L'atelier 4 présente les **scénarios opérationnels**, à savoir les **modes opératoires concrets** permettant la mise en œuvre des scénarios stratégiques. Ces scénarios sont organisés selon les différentes phases de la **cyber kill chain** et font l'objet d'une évaluation quant à leur **vraisemblance**.

Exemple de scénario opérationnel détaillé .

Scénario : Cyber espionnage d'État visant l'exfiltration de plans d'opération classifiés

Risque prioritaire	Décision	Justification
Cyber espionnage d'État (plans classifiés)	**Réduction**	Impact souverain inacceptable → MFA, SIEM, DLP, SOC 24/7
Menace interne malveillante	**Réduction**	Accès légitimes abusés → moindre privilège, DLP, traçabilité
Compromission du command server	**Réduction**	Criticité opérationnelle maximale → architecture bastion, isolation
Rupture des communications C2	**Réduction**	Disponibilité non négociable → redondance SATCOM, PCA/PRA
Risque lié au prestataire satellite	**Transfert partiel**	Responsabilité contractuelle transférée au prestataire via clauses de sécurité, audits tiers et cyberassurance couvrant les incidents de la chaîne d'approvisionnement
Erreurs humaines mineures (personnel négligent)	**Acceptation encadrée**	Risque résiduel faible après formation, revue annuelle, validation formelle de la direction
Services administratifs non critiques	**Acceptation encadrée**	Impact opérationnel limité, surveillance périodique suffisante

Vraisemblance globale du scénario : **Moyenne à élever** en l'absence de mesures de sécurité renforcées.

Atelier 5 : Traitement du Risque

Objectif

L'atelier final vise à **synthétiser les risques** et à élaborer une **stratégie de traitement**. Celle-ci se traduit par des **mesures de sécurité** dans un **plan de traitement**. Les risques résiduels sont notés et un suivi est mis en place.

Stratégie de traitement du risque

Risque prioritaire	Mesures recommandées	Décision
Espionnage sur données citoyennes	- Authentification multifacteur (MFA) renforcée pour tous les accès sensibles - Cloisonnement réseau strict entre zones opérationnelles et administratives - Journalisation centralisée et corrélation d'événements (SIEM) - Data Loss Prevention (DLP) sur les flux sortants - Supervision SOC 24/7 - Durcissement des postes d'administration	**Réduction immédiate**
Menace interne	- Principe du moindre privilège appliqué strictement - Revues de droits régulières et traçabilité des accès - Séparation des tâches - Contrôle des exports et des supports amovibles - Sensibilisation et formation continue	**Réduction prioritaire**
Systèmes non corrigés	- Gestion centralisée des correctifs (patch management) - Inventaire et qualification des actifs critiques - Fenêtres de maintenance planifiées - Tests avant déploiement en production	**Réduction planifiée**
Compromission du command server	- Architecture bastion pour l'administration - Isolation des systèmes critiques - Surveillance renforcée des comportements anormaux - Procédures de réponse à incident dédiées	**Réduction immédiate**
Rupture des communications C2	- Redondance des liaisons critiques - Cloisonnement réseau et	**Réduction prioritaire**

Risque prioritaire	Mesures recommandées	Décision
	segmentation par zone - Surveillance continue des liaisons satellitaires - Plans de continuité d'activité (PCA/PRA)	
Risques opérationnels mineurs	- Surveillance périodique - Acceptation formalisée par la direction - Revue annuelle	**Acceptation encadrée**

Architecture Zero Trust

L'ANSSI préconise la mise en œuvre progressive d'une **architecture Zero Trust**, conçue pour limiter la confiance implicite et renforcer les mécanismes de contrôle liés à l'identité, aux équipements et au contexte. Dans un environnement C2, cette approche requiert :

- **Vérification continue** de l'identité et de l'état de sécurité des équipements
- **Micro-segmentation** du réseau pour limiter les mouvements latéraux
- **Contrôle d'accès adaptatif** basé sur le contexte (localisation, heure, risque)
- **Surveillance renforcée** et analyse comportementale des utilisateurs et entités (UEBA)
- **Défense en profondeur** combinant prévention, détection et réponse

Plan d'action

Horizon	Action	Responsable	Ressources
0–3 mois	Déploiement MFA sur tous les comptes à privilèges	RSSI + DSI	Budget SI, éditeur IAM
0–3 mois	Mise en place journalisation centralisée + supervision SOC	RSSI + SOC	Plateforme SIEM (ex : Wazuh/Splunk)
0–3 mois	Durcissement command server et postes d'administration	DSI + Équipe SI	Guides ANSSI, CIS Benchmarks
3–6 mois	Segmentation réseau renforcée + micro-segmentation	DSI + Architecte réseau	Firewall nouvelle génération, VLAN
3–6 mois	Déploiement DLP + contrôle des exports et supports amovibles	RSSI + SOC	Solution DLP, politique SI
3–6 mois	Révision des habilitations et procédures de contrôle interne	RSSI + RH + État-major	Revue des droits, PAM
6–12 mois	Mise en œuvre progressive architecture Zero Trust	RSSI + DSI + Architecte	Budget projet, accompagnement ANSSI
6–12 mois	Patch management centralisé + inventaire des actifs	DSI	Outil CMDB, fenêtres de maintenance
6–12 mois	Formation et sensibilisation continue du personnel	RSSI + RH	Module e-learning, exercices phishing
> 12 mois	Révision annuelle des risques résiduels	RSSI + Direction	Comité de pilotage sécurité
> 12 mois	Adaptation stratégie sécurité aux nouvelles menaces	RSSI + SOC + État-major	Veille CTI, retours d'expérience

6. Communication et documentation

Dans le cadre de cette étude EBIOS Risk Manager, l'ensemble du processus de gestion des risques doit être documenté de manière formelle afin d'assurer la traçabilité de l'analyse, la cohérence des décisions et le suivi des mesures de sécurité dans le temps. Cette documentation doit regrouper le cadrage initial, le périmètre de l'étude, les actifs critiques, les valeurs métier, les événements redoutés, les sources de risque, les scénarios stratégiques et opérationnels, ainsi que les choix de traitement retenus.

La méthode EBIOS RM prévoit également la production d'une synthèse des risques étudiés, d'un plan de traitement du risque, d'une identification des risques résiduels et d'un cadre de suivi permettant d'inscrire la sécurité dans une logique d'amélioration continue. Dans ce cas, le dossier final doit donc permettre aux responsables gouvernementaux de visualiser clairement les risques prioritaires pesant sur la base militaire C2, les impacts possibles sur les missions, les mesures recommandées et les arbitrages à valider.

Éléments à documenter

Élément documentaire	Contenu attendu
Cadrage de l'étude	Objet, périmètre métier et technique, acteurs impliqués, hypothèses et limites
Analyse métier	Missions critiques, valeurs métier, événements redoutés, niveau de gravité
Analyse de la menace	Sources de risque, objectifs visés, cartographie des menaces
Scénarios de risque	Scénarios stratégiques, scénarios opérationnels, chemins d'attaque, vraisemblance
Traitement du risque	Mesures de sécurité, priorités, calendrier, niveau de risque résiduel
Suivi et gouvernance	Responsables, indicateurs, fréquence de revue, validation des risques résiduels

BRIEFING EXÉCUTIF — À l'attention des Responsables Gouvernementaux

Classification : **CONFIDENTIEL** — Usage restreint
Date : Mars 2026 | Rédigé par : Cédric / Cyberporto- Auditeur

---

Objet

Ce briefing présente de façon synthétique les conclusions de l'analyse EBIOS Risk Manager conduite sur la base militaire de Command and Control (C2). Il vise à éclairer les décideurs sur les risques prioritaires, leurs impacts opérationnels et les arbitrages nécessaires.

Contexte stratégique

La base C2 assure le commandement des opérations militaires, la coordination des unités et la protection de renseignements classifiés. Toute compromission de son infrastructure aurait un impact direct sur la souveraineté nationale et la conduite des opérations.

Risques prioritaires identifiés

Risque	Impact	Niveau
Cyber espionnage d'État	Fuite de plans d'opération top secret	🔴 Critique
Compromission du command server	Altération d'ordres, sabotage des missions	🔴 Critique
Menace interne malveillante	Divulgation de données classifiées	🟠 Élevé
Rupture des communications C2	Perte de commandement opérationnel	🟠 Élevé
Risque prestataire satellite	Compromission indirecte du réseau C2	🟡 Moyen

Mesures prioritaires à valider

1. **Immédiat : Déployer le MFA sur tous les accès à privilèges et activer la supervision SOC 24/7**
2. **Court terme : Renforcer la segmentation réseau et déployer des solutions DLP**
3. **Moyen terme : Initier la transition vers une architecture Zero Trust**
4. **Contractuel : Imposer des clauses de sécurité au prestataire satellite (SLA, audit, cyber-assurance)**

Décisions demandées aux responsables

- Valider l'acceptation formelle des risques résiduels mineurs (services administratifs non critiques)
- Approuver le budget alloué aux actions immédiates (MFA, SOC, SIEM)
- Mandater le RSSI comme responsable du pilotage du plan d'action
- Valider le transfert partiel de responsabilité vers le prestataire satellite via contrat

---

Prochain point de suivi : Comité de pilotage sécurité dans 3 mois pour revue des actions immédiates.

Annexe 1 – Glossaire des termes techniques

Terme	Définition
C2 (Command and Control)	Système ou centre de commandement permettant de planifier, coordonner, diriger et contrôler des opérations militaires ainsi que les flux d'information associés
Command server	Serveur central utilisé pour piloter des fonctions critiques de commandement, centraliser des informations et diffuser des ordres ou des données opérationnelles
Zero Trust	Modèle de sécurité fondé sur l'idée qu'aucun utilisateur, terminal ou service ne doit être considéré comme fiable par défaut, même à l'intérieur du réseau

Annexe 2 – Acronymes et sigles

Acronyme	Signification	Définition simple
C2	Command and Control	Centre ou système de commandement permettant de diriger, coordonner et contrôler des opérations militaires
DMZ	Demilitarized Zone	Zone réseau intermédiaire entre Internet et le réseau interne, utilisée pour exposer certains services tout en protégeant le SI interne
MFA	Multi-Factor Authentication	Authentification reposant sur plusieurs facteurs de preuve, par exemple mot de passe et code temporaire
SIEM	Security Information and Event Management	Solution qui centralise et analyse les journaux de sécurité pour détecter des événements suspects
SOC	Security Operations Center	Centre opérationnel chargé de surveiller les systèmes, qualifier les alertes et répondre aux incidents de sécurité
DLP	Data Loss Prevention	Mécanismes destinés à prévenir la fuite, l'exfiltration ou l'usage non autorisé de données sensibles
UEBA	User and Entity Behavior Analytics	Analyse comportementale des utilisateurs et des entités, utilisée pour détecter des comportements anormaux à partir des habitudes observées
OSINT	Open Source Intelligence	Collecte et analyse d'informations accessibles publiquement pour obtenir du renseignement utile
PCA	Plan de Continuité d'Activité	Plan destiné à maintenir les activités essentielles pendant un incident majeur
PRA	Plan de Reprise d'Activité	Plan visant à restaurer les systèmes et services après une interruption ou un sinistre

- **SATCOM** : Satellite Communications, communications par satellite.
- **CIA** : Confidentiality, Integrity, Availability, soit confidentialité, intégrité, disponibilité.
- **IAM** : Identity and Access Management, gestion des identités et des accès.